MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 051 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · ENCLAVE ENGINEERING

Hardening Windows Server 2025 for CUI: 12 Controls That Fought Back

97 checks run against our CUI vault every week. These 12 NIST 800-171 controls did not pass quietly. What each check found and what fixed it.

BY **PATRICK CARUSO**

READING TIME · 6 MIN

WINDOWS-SERVER · CUI-ENCLAVE · NIST-800-171 · HARDENING · STIG · FIPS

The MacTech CUI Vault runs on a single hardened Windows Server 2025 host in Azure, behind a front door, reachable by Bastion, with the CUI file boundary and the monitoring service on the same machine. Every Sunday at two in the morning a validator runs ninety-seven checks against it, each tied to a NIST SP 800-171 requirement, and writes the result into a signed chain. Most pass without comment. This piece is about the ones that did not, because the ones that fight back are where the actual engineering lives.

Here is the direct answer. Twelve controls resisted, for four kinds of reason: the operating system was newer than the certification behind it, the default was wrong in a way that only matters for CUI, the cloud architecture created a gap the STIG never contemplated, or something had been installed that nobody documented. The list below takes them in that order, with the control, what the check found, and what closed it. It is written for the engineer who has been handed a Windows box and a copy of 800-171 and told to make one satisfy the other.

FIELD COPY
ISSUE Nº 051
WINDOWS SERVER

97

HARDENING CHECKS EXECUTED AGAINST THE VAULT HOST EVERY CANONICAL RUN, EACH A FORENSIC PACKET WITH THE COMMAND, THE EXPECTED RULE AND THE OBSERVED VALUE

103 → 26

INBOUND FIREWALL ALLOW RULES ON THE HOST BEFORE AND AFTER THE REVIEW THAT FOUND AN UNDOCUMENTED TUNNEL SERVICE

-3

SPRS POINTS THE FIPS SLIDING SCALE DEDUCTS WHEN ENCRYPTION IS EMPLOYED BUT THE MODULE IS NOT CMVP-VALIDATED - THE POSITION WINDOWS SERVER 2025 PUT US IN

The OS was newer than the certificate

3.13.11 · FIPS-validated cryptography. The check is simple: FIPS mode enabled. It passed. The problem is that the requirement says *validated*, and validated means a CMVP certificate for the cryptographic module in use. When we checked, the module shipped in Windows Server 2025 build 26100 had no certificate of its own on the CMVP list. FIPS mode on a module with no certificate is encryption employed but not validated, and the assessment methodology's sliding scale deducts three of the requirement's five points for exactly that state. There is no configuration fix. We carry it on the POA&M with the certificate's progress as the milestone, and the deployable vault edition runs on Ubuntu 22.04 with CMVP certificate 4794 for that reason.

3.13.16 · CUI at rest. BitLocker on every fixed volume, which the check confirms volume by volume. It failed on a volume nobody thinks about: the page file had been placed on a data disk that was not yet encrypted. CUI in memory gets paged; a page file on an unencrypted volume is CUI at rest outside the boundary. The fix was moving the page file to the encrypted OS volume, which needs a reboot the change window had to allow for.

The default was wrong for CUI

3.1.21 and 3.8.7 · Portable storage. Windows does not disable USB mass storage by default, and on a server nobody plugs anything into it is easy to leave alone. Two checks look for the USBSTOR service start value set to disabled. They failed on first observation and passed on re-observation after the setting was applied, which is the shape of evidence an assessor likes: a dated failure, a dated fix, both in the chain.

3.4.8 and 3.4.9 · Application allow-listing. AppLocker was configured. It was in audit-only mode, which logs what it would have blocked and blocks nothing. One check confirms the Application Identity service is running; a second confirms the policy is present; a third, the one that failed, confirms enforcement rather than audit. Flipping the mode is trivial. Knowing that the earlier two checks pass in a state where nothing is protected is the reason there are three.

3.3.4 · Audit-log failure response. The requirement says alert when logging fails. The check looks for the CrashOnAuditFail setting, which halts the host rather than run unlogged. It is a blunt instrument and a defensible one on a single-purpose CUI host, and it is off by default.

3.14.6 · Protected LSA. Credential-theft tooling reads the Local Security Authority's memory. Running LSA as a protected process is one registry value and is not the default on Server 2025. The check found it unset.

3.5.10 · NTLMv2 only. The compatibility level that refuses LM and NTLMv1 and the flag that stops storing LM hashes. Both are older than most of the people configuring them, both still default to permissive, and the check found the compatibility level short of where the STIG puts it.

3.13.8 · Transport cryptography. TLS 1.0 and 1.1 disabled, SMBv1 removed. Server 2025 ships with SMBv1 absent but the TLS registry keys still have to be written, and the check found 1.1 enabled on the server side.

The cloud architecture created the gap

3.13.1 · Boundary protection. The host has a public IP address so that the front door can reach it. That is a finding, and it is the finding we have discussed most with assessors. Closing it properly means private link to the origin, which on Azure Front Door requires the Premium tier, and we declined the cost. The compensating controls are documented and checked: port 80 closed, port 443 accepting traffic only from the front door's service tag, the front door's identifier header enforced on every request. The check verifies the network security group state; the control narrative explains why the residual risk is accepted. An assessor can disagree with the acceptance. They cannot say it is undocumented.

3.1.11 · Session termination. Remote sessions reach the host through Bastion, and Bastion has its own idle timeout that is not the host's. The check reads the host's RDP session limits: fifteen minutes idle, five minutes disconnected, eight hours maximum. The host values were set; the Bastion timeout was longer than the host's, which meant a session could sit idle at the Bastion layer past the host's limit. Both now agree, and the check reads both.

◆ WHY NOT JUST APPLY THE STIG?

We did, as a baseline. The DISA STIG for Windows Server tells you the setting. It does not tell you which settings an assessor will ask about in the order the 800-171 objectives put them, and it does not tell you what happens on a host that is also a CUI file boundary behind a cloud front door. The twelve below are where the STIG's answer was necessary but not sufficient.

◆ THE EVIDENCE MODEL

Each check records the command issued, the rule expected, the value observed and a verdict, serialised canonically and hashed into a signed chain per run. A failed check is evidence too; it is what the POA&M cites. That is why we can publish this list at all.

Something was installed that nobody documented

3.4.7 and 3.13.1 again · The tunnel. The monitoring service's new-service correlation rule fired on a service that had been installed in May and was running on automatic start: a Cloudflare tunnel daemon, holding an outbound session so that an administrative surface could be reached without going through the front door. It was a convenience, it was undocumented, and it was an inbound path around every boundary control above. It was removed, and the host firewall review that followed cut the inbound allow rules from a hundred and three to twenty-six. The listening-ports check, which bounds the number of distinct TCP listeners, is what would catch the next one.

3.4.6 · Least functionality. The same review found roles and features installed for a purpose nobody could name. The check compares installed roles against a banned list; the fix was removal, and the interesting part was that the list of what should be installed had never been written down, which is a 3.4.1 baseline gap that the 3.4.6 check exposed.

What the twelve have in common

None of them were found by reading the STIG, although the STIG had the right setting for eight of them. They were found by running a check that names a control, expects a value, and records what it observed, on a schedule, with a signature. A failed check on a Sunday in August is not an embarrassment. It is the evidence that the control was being evaluated, and the dated fix that follows it is the evidence an assessor actually wants.

The full set of checks, the cadence they run on, and the things the monitoring does not claim to prove are on the EnclaveWatch spec sheet. Which of the hundred and ten controls the managed vault carries for a subscriber, and which stay theirs, is in the responsibility matrix. For the choice between STIG and CIS as the baseline behind all of this, Issue 28 is the piece to read first. ◆